Portfolio Index & Lessons Learned

Week 12 · Care Access Navigator · HealthLine Regional Medical Center (HRMC)

Final documentation set, success criteria, lessons learned, limitations and project closure

Author	Akhila Chennamaneni
Date	November 5, 2026
Version	v1.1
Project window	2026-08-17 to 2026-11-05 (12 weeks)
Headline results	End-to-end tests 10/10 passed; control test pass rate 57.1% (10/13 audit) → 85.7% (11/03); 9/18 corrective actions verified; 3 of 6 audit findings closed with before/after evidence
Positioning	Hands-on cybersecurity lab capstone using synthetic identities and events; no production healthcare data and no certification claimed

1. Documentation set

Deliverable	Contents	Status
Project charter `Care_Access_Navigator/01_Docs/01_Project_Planning/CAN_DOC_Week1_Day1_Objective_Scope_Baseline_v1.0.pdf`	Problem, objectives, scope, stakeholders, success criteria	Done
Project design documentation `Care_Access_Navigator/01_Docs/01_Project_Planning/CAN_DOC_Project_Design_Documentation_v1.3.docx`	Design, tech stack, timeline, rubric crosswalk	Done (v1.3, status verified 11/04)
Architecture `Care_Access_Navigator/01_Docs/01_Project_Planning/CAN_DOC_Week1_Day4_High_Level_Architecture_Data_Flow_v1.0.pdf`	IAM, applications, SIEM, GRC and data flow	Done
Asset inventory `Care_Access_Navigator/04_Applications/01_Application_Inventory/CAN_DOC_Asset_Inventory_v1.0.xlsx`	Applications, infrastructure, data types, live identities, privileged functions	Done
RBAC matrix, least privilege, SoD, access requests `Care_Access_Navigator/03_IAM_Lab/CAN_DOC_RBAC_SoD_Access_Request_v1.0.pdf`	Role x app matrix, SoD conflicts, workflow, 11-request register	Done
Logs `Care_Access_Navigator/05_Logs/EVIDENCE-INDEX-SHA256.txt`	Exported login/admin events, EHR sample, detections, automation audit	Done
IAM build log `Care_Access_Navigator/03_IAM_Lab/CAN_DOC_Keycloak_EntraID_Build_Log_v1.0.docx`	Keycloak + Entra ID federation build	Done

Deliverable	Contents	Status
Entra ID identity governance design `Care_Access_Navigator/03_IAM_Lab/CAN_DOC_Entra_ID_Identity_Governance_Design_v1.0.pdf`	Tenant set-up, app role -> realm role -> group design, JML/review/MFA rules, gaps	Done (11/05)
JML procedures + evidence `Care_Access_Navigator/06_Evidence/07_JML_Lifecycle/Care_Access_Navigator_JML_Lifecycle_Evidence.pdf`	Joiner, mover, leaver with Entra and Keycloak evidence	Done
Authentication & privileged access `Care_Access_Navigator/07_GRC/02_Controls/CAN_DOC_Authentication_and_Privileged_Access_v1.0.pdf`	Baseline, privileged access matrix, service/vendor register, tests	Done
Access review `Care_Access_Navigator/06_Evidence/05_Access_Reviews/CAN_DOC_Access_Review_AR-2026-Q4_v1.0.xlsx`	Quarterly review AR-2026-Q4 with flags and sign-off sheet	Done (signed 2026-11-09, CA-05 verified)
SIEM use cases + incident `incident_response_1/task5_ir_documentation/README.md`	Wazuh rules, CAN-ID identity rules, IR1-2026-002 report	Done
Risk register `Care_Access_Navigator/07_GRC/01_Risks/CAN_DOC_CISO_Risk_Assessment_R01-R05_v2.0.pdf`	R01-R05 in CISO Assistant: inherent, current and residual levels, treatment, linked controls	Done
Control matrix + compliance mapping `Care_Access_Navigator/07_GRC/03_Compliance/CAN_DOC_CISO_HIPAA_Audit_v2.0.xlsx`	18 controls; HIPAA audit (25 requirements: 17 compliant, 7 partial, 1 non-compliant) and NIST CSF 2.0 mapping (15 subcategories) in CISO Assistant; SP 800-53/ISO/PCI in the catalog	Done
Exceptions + corrective actions `Care_Access_Navigator/07_GRC/04_Remediation/CAN_DOC_CISO_Corrective_Action_Tracker_v1.0.pdf`	8 exceptions (EX-01 resolved) and 18 corrective actions + CAN-FIND-001 as CISO Assistant findings, tracked to verification	Done
Evidence index `Care_Access_Navigator/06_Evidence/CAN_DOC_Evidence_Index_v1.0.xlsx`	Evidence by control with SHA-256; 43 evidence items with files in CISO Assistant	Done
End-to-end test report `Care_Access_Navigator/06_Evidence/04_Test_Results/CAN_DOC_End_to_End_Test_Report_v1.0.pdf`	TC-01 to TC-10: 10/10 passed	Done
GRC dashboard `Care_Access_Navigator/08_Reporting/02_Dashboards/EV-16_CISO_Dashboard_Compliance_20261105.png`	CISO Assistant analytics, risk matrix and compliance progress (replaces Tableau, EX-08); KPI design PDF kept	Done (EX-08 pending instructor)
CISO Assistant learning project `learning/evidence/README.md`	Plan, tutorial, observability notes, exports and proof	Done (reflection to finalise)

Deliverable	Contents	Status
5-minute demo `Care_Access_Navigator/09_Portfolio/04_Demo/CAN_DOC_5_Minute_Demo_Script_v1.1.pdf`	Script with live commands and backup evidence	Done (rehearse)
Demo deck `Care_Access_Navigator/09_Portfolio/04_Demo/CAN_DOC_MVP_Demo_v1.1.pptx`	MVP deck, slides 3 and 10 corrected to verified status	Done (export PDF from PowerPoint/Keynote)

2. Success criteria (12-week plan, section 17)

Area	Standard	Evidence	Result
IAM	At least one complete JML workflow, RBAC matrix, access request and access-review demonstration	JML cycle (Entra + Keycloak) and automated JML in TC-01/03/04; RBAC app matrix enforced; access review run	**Met**
Monitoring	At least three useful detection use cases with controlled test events and investigation	CAN-ID-001/002/004/005/007 fired on controlled events; Wazuh rules 100210/100221/100231 in IR 1	**Met**
Incident response	One end-to-end simulated access incident from detection through lessons learned	IR1-2026-002 (Tara Jones, ePHI exfiltration): alert to containment in 49 s, forensics, RCA, recovery	**Met**
GRC	Risk register, control matrix, evidence index, gap assessment, exceptions/remediation, dashboard	Registers in CISO Assistant since 11/04 (5 risks, 18 controls, 43 evidence items, 8 exceptions, 19 findings); dashboards in CISO Assistant	Met (EX-08 pending)
Compliance	Controls mapped to HIPAA Security Rule and NIST concepts without claiming certification	16 controls mapped to HIPAA, CSF 2.0 and SP 800-53 (plus ISO 27001 and PCI DSS); CISO Assistant audits of HIPAA (25 requirements) and CSF 2.0 (15 subcategories)	**Met**
Portfolio	Architecture, evidence, procedures, test cases and 5-minute demo presentation-ready	This index; demo script; corrected deck	Met (rehearse demo)

3. Lessons learned

Lesson	What happened	What changed
Verify status, don't trust it	The board export and two status decks said items were done that were not. An evidence-based audit (11/02) found 8 items not started and 3 false claims.	Every status claim now points to an evidence file; the deck was corrected (CA-14).
Configuration that exists is not configuration that works	An MFA flow had been built but was bound to nothing, its OTP step used 'user configured' (people without OTP skipped MFA), and a role condition sat where Keycloak ignores it.	Test the negative path: a privileged user without OTP must be stopped (EV-13).
Federation creates a second copy of every identity	Jeevan Smith was disabled in Entra and Keycloak, but the Keycloak copy kept the billing role mapped from Entra. Only the access review caught it (TC-09).	Leavers go through can_iam.py leaver, which strips IdP-mapped roles; the review checks DISABLED_BUT_HAS_ACCESS.
Detection rules need regression tests	CAN-ID-001 alerted once per user for all time, so a second attack on the same account was silent. Only the end-to-end test found it (TC-05).	Rule fixed (CA-10) and retested with a fresh burst; rerun e2e_tests.py after every rule change.

Lesson	What happened	What changed
Test design can hide results	The TC-05 attempts fell inside the 10-minute window of an earlier test.	Space tests beyond the detection window or use fresh test identities.
Cost limits shape compliance	Removing the Log Analytics workspace to stop charges created finding F-03 (no 12-month logs).	Accepted as exception EX-02 with compensating controls and an expiry; any fix needs a cost estimate first.
Secrets hygiene in a public repository	The lab .env with passwords had been committed to a public repo.	.env untracked and ignored, .env.example added, rotation tracked (CA-12).
Write down tool substitutions early	IR 1 used Debian/QEMU in place of Parrot/VirtualBox.	Substitution note in every deliverable; instructor acceptance requested (EX-06).
Hash evidence when you collect it	SHA-256 indexes let folders be reorganised without losing integrity: moving folders kept every index valid.	Index every evidence folder at collection time; never rename files inside one.
Stop before you copy	The CISO Assistant database was copied from Windows while the app was running and arrived corrupt.	Recovered with sqlite3 .recover; now always docker compose down before copying or backing up.
Use dedicated test identities	Week 5 tests used new accounts (test.billing2, test.clinician2) instead of resetting existing users' passwords.	Test accounts are labelled employment_type=test-account and reviewed quarterly like any other.

4. Limitations

- Applications are OIDC clients without a full front end; access is proven at the identity provider (auth code issued or denied), which is where the control sits.
- Entra ID is a personal free-tier tenant: no Conditional Access, Access Reviews or group-based app assignment (P1/P2). MFA for Entra users relies on Security defaults, enabled and evidenced 11/05 (EV-17, EX-01 resolved).
- Log retention is 90 days (EX-02); there is no running SIEM for the identity layer. Detections run on demand with can_iam.py detect, and the IR lab used a real Wazuh manager.
- The IR lab substitutes Debian 12 under QEMU for Parrot OS on VirtualBox (EX-06).
- Keycloak runs in development mode over HTTP on localhost (EX-05).

5. Open items at closure

ID	Item	Owner	Due
CA-03	No 12-month log retention	Security Officer	2027-01-31
CA-06	IdP over HTTP	IT Support	2027-01-31
CA-08	test.vendor1 has no sponsor or end date	IT Manager (sponsor)	2026-11-10
CA-12	Lab passwords exposed in public git history	IAM Analyst	2026-11-10
CA-13	Privileged users not yet enrolled in OTP	IAM Analyst	2026-11-10
CA-15	PKCE not enforced on public clients	IAM Analyst	2026-12-15
CA-16	Automation signs in as the human admin	IAM Analyst	2027-01-31
CA-18	IT-Support can sign in to hr-app although its role description excludes HR data	HR Manager + IAM Analyst	2026-12-15
CA-17	Entra broker client secret expiry unknown	IAM Analyst	2026-11-10

6. Next steps (future version)

- Self-service access-request portal feeding can_iam.py joiner (design doc section 11).
- Stream Keycloak events to Wazuh so CAN-ID rules run continuously, with 12-month archive (closes EX-02).
- TLS reverse proxy and production-mode Keycloak (closes EX-05).
- Entra ID P2 trial for Conditional Access and Access Reviews, with a cancellation reminder (cost approval first).

Closure: Project closure: the Weeks 1-12 board items are delivered, with the open items above carried into the corrective-action tracker with owners and dates. Sign-off by the project sponsor: _____ Date: _____